

web Exploitation

🕒 Created	December 6, 2025 10:55 PM
👤 Writer	⑤ Samin Ahmed Chowdhury
➡ Vedio1	https://youtu.be/1GJ_LwNw6sc?si=DzHpvgpNhjFUR6NI
🔗 github link	https://github.com/LeonardoE95/yt-en/tree/main/src/2024-02-14-web-exploitation-introduction
🔗 CTF solve	https://youtube.com/playlist?list=PL_kRRBu3ISwte6U0Yzo-pHNe5VI0tr7n-&si=p5mdMHIATJUwclZX
🔗 Srcbank	https://github.com/ssrdio/SecureBank

<https://owasp.org/www-project-top-ten/>

Aa Resources	🔗 URL
<u>From where i learn</u>	https://youtu.be/1GJ_LwNw6sc?si=pRi3RoBm0Q3lvJTl
<u>optional</u>	https://youtube.com/playlist?list=PLJnLaWkc9xRitBGPK5CcyoWCcPCeTYoqw&si=I5NEqRqtmN42fA1H
<u>CTF Solves</u>	https://youtube.com/playlist?list=PL_kRRBu3ISwte6U0Yzo-pHNe5VI0tr7n-&si=p5mdMHIATJUwclZX
<u>optional full</u>	https://youtu.be/ik2p4Rz4QzM

<https://owasp.org/www-project-juice-shop/>

SQL injec : <https://portswigger.net/web-security/sql-injection/cheat-sheet>

XSS : https://youtube.com/playlist?list=PLYMKlsvcubZpBr934Gn9gPd-vesTmCR5X&si=SWAexKWB6Z1oBfH_

Common SQL Verbs

- SQL Statements begin with verbs. Let's take a look at a few common verbs:
 - **SELECT** – Retrieves data from a table
 - **INSERT** – Adds data to a table
 - **DELETE** – Removes data from a data
 - **UPDATE** – Modifies data in a table
 - **DROP** – Delete a table 😊
 - **UNION** – Combines data from multiple queries

Other Common Terms

- A few extra terms to know (for now):
 - **WHERE** – Filters records based on specific condition
 - **AND/OR/NOT** – Filter records based on multiple conditions
 - **ORDER BY** – Sorts records in ascending/descending order

UserID	UserName	FullName	Email	Country
1	Frank	Frank Castle	punisher@marvel.com	US
2	Natasha	Natasha Romanova	blackwidow@marvel.com	RU
3	Peter	Peter Parker	spiderman@marvel.com	US
4	Tony	Tony Stark	ironman@marvel.com	US
5	Clint	Clint Barton	hawkeye@marvel.com	US

What happens when we run the following statements?

- `SELECT * FROM Users;`
- `SELECT UserID, UserName FROM Users;`
- `SELECT * FROM Users WHERE Country='RU';`
- `SELECT * FROM Users WHERE Country='US' AND UserName='Frank';`

Example – “Users” Table

Special Characters

- Lastly, let's talk some important special characters
 - ' and " – string delimiters
 - --, /*, and # – comment delimiters
 - * and % - wildcards
 - ; - Ends SQL statement
 - Plus a bunch of others that follow programmatic logic - =, +, >, <, (), etc



SQL Injection Defenses

- Defense 1: Parameterized Statements
 - Ensure inputs (parameters) are used safely in SQL statements
 - Example: `"SELECT * FROM users WHERE email =?"`;
 - Example: `"SELECT * FROM users WHERE email = " + email + """`;
- Defense 2: Sanitizing Input

XML External Entities (XXE)

Introduction

What is XXE?



Attacking systems that parse XML input

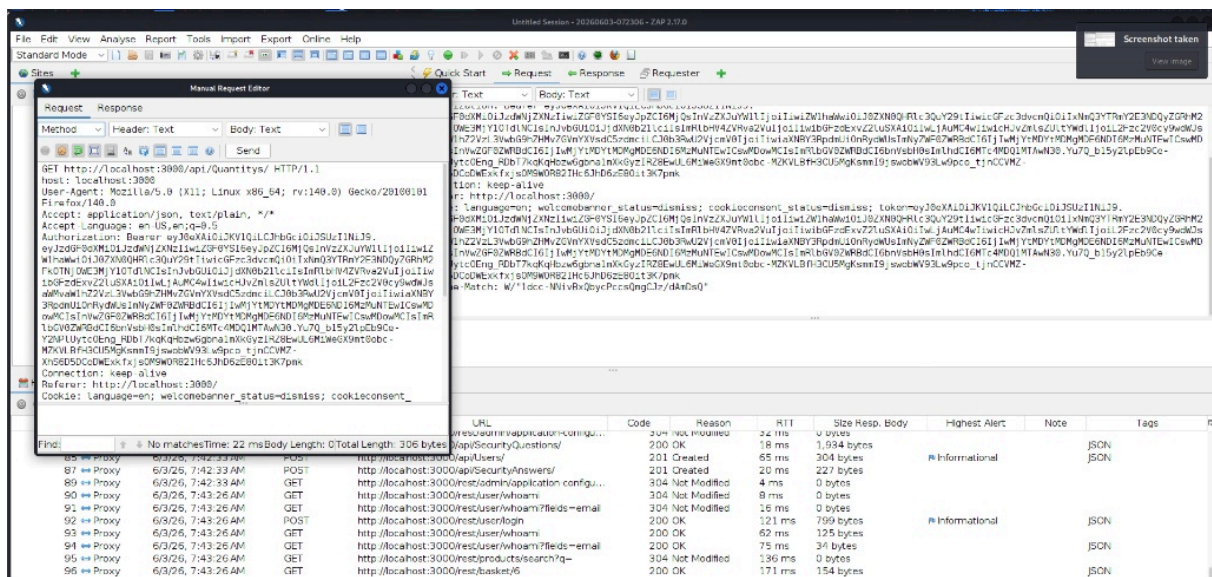


Abuse SYSTEM entity and get malicious

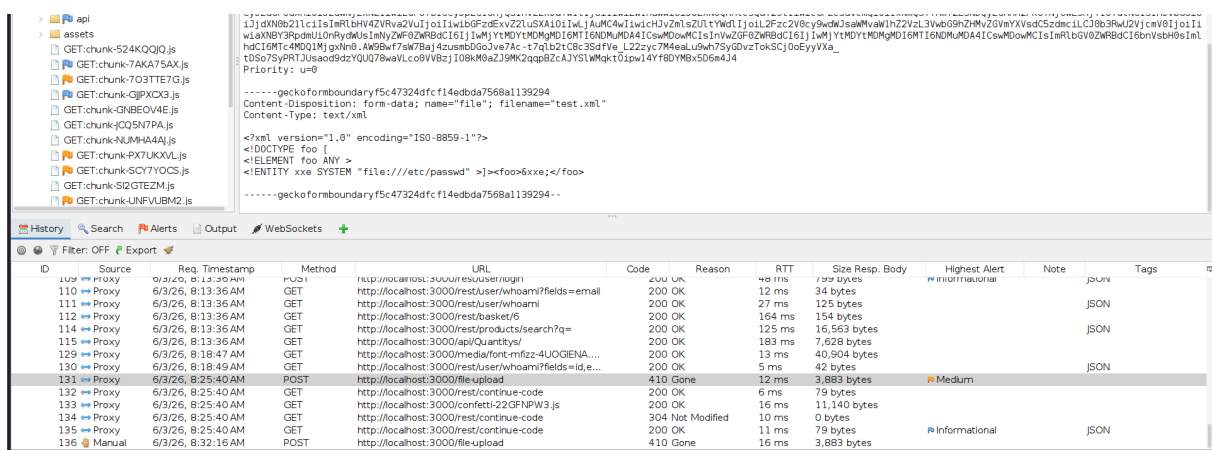


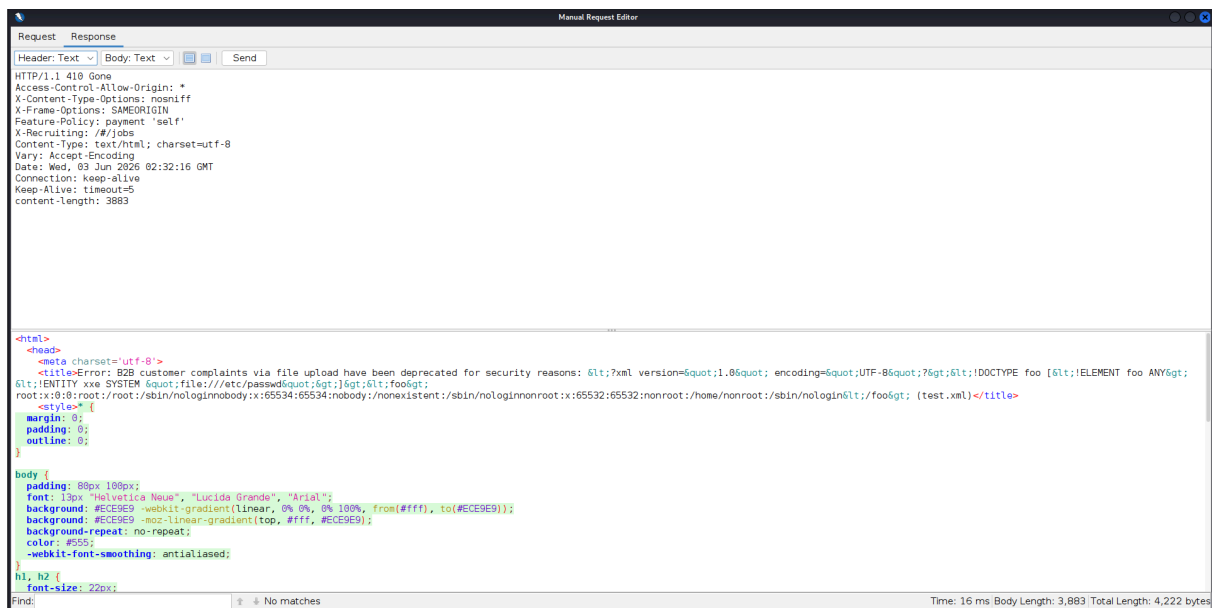
Attacks include denial of service, local file disclosure, remote code execution, and more

next video is that we're going to take



Just click history find ALL PROZY

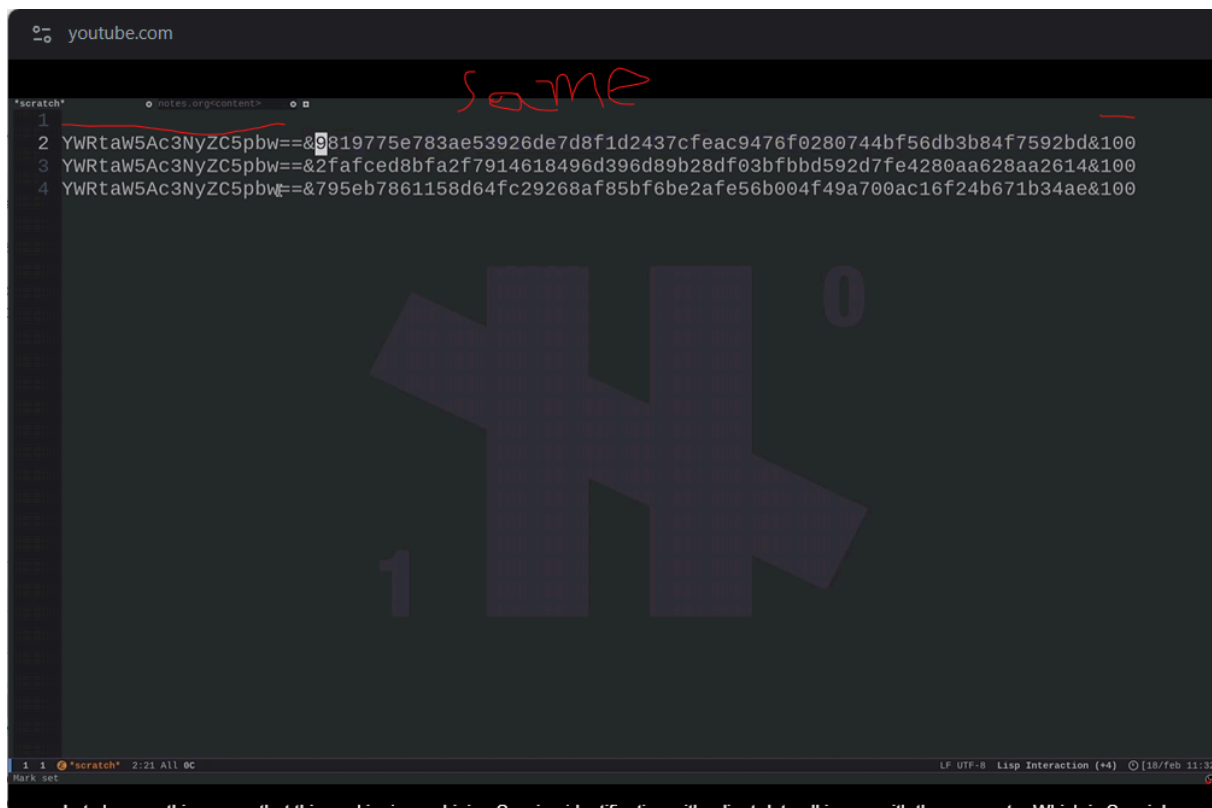




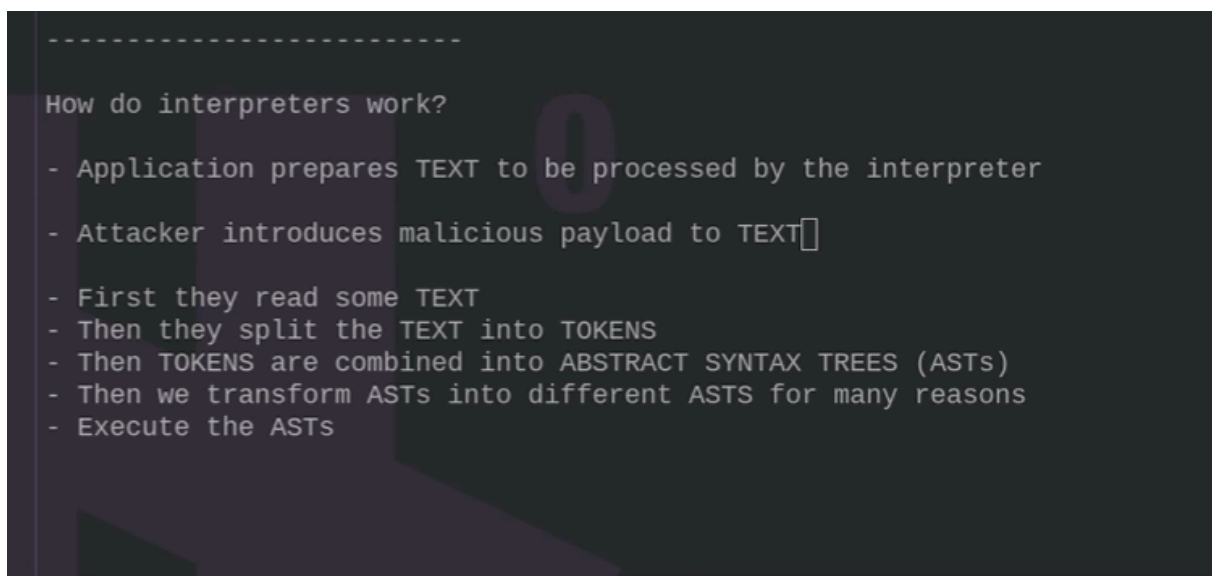
How to Prevent XSS

Step	Action
Encoding	• < becomes &lt; • <script> becomes &lt;script>
Filtering	• <script> becomes script
Validating	• Compare input against white list
Sanitization	• Combination of escaping, filtering, and validation

On cookies



use it on decode



Basic payload

```
' OR 1=1 #
```

To extract password

```
' OR 1=1 #
```